

Privilege Escalation in Red Teaming

Date : 30/11/2025

Introduction :

Privilege Escalation means gaining higher permissions than the originally given. In every operating systems and applications that will work on permission levels, there are many users who are not allowed to do everything on a system

It is a situation in which an attacker increases their permission levels beyond what was originally assigned, in Red Teaming operations, privilege escalation is considered as an important step because it determines how much damage an attacker can cause.

Explanation :

Most of the Cyberattacks do not immediately give full system access, in the initial access usually the system provides the low level privileged user account, low privileged systems and users have limited abilities like, no access to sensitive data , no permission to install or modify some critical software.

Privilege escalation allows attackers to bypass these restrictions, in this attackers mainly look for some loop holes and weaknesses like poor software configuration, incorrect permission settings etc.

There are some certain things in which they are used for the privilege escalation are **WinPEAS/LinPEAS, PowerSploit, Linenum, Metasploit Framework** etc.

Types of Privilege Escalation :

1. **Vertical Privilege Escalation** : This privilege escalation occurs when an normal or low level user gains higher level privileges, for example we say a standard user account becomes an administrator or root user, this is very most dangerous because it allows full control over the system and attackers can easily disable any security controls.
2. **Horizontal Privilege Escalation** : This escalation happens when an user access data or resource of another user with the same privilege level, It is very much common in the web applications, for example we say one user is viewing or modifying another user data without permission.

Common cause for these are :

- Weak or incorrect file permissions which are given at first
- Vulnerable and misconfigured service in the systems
- Outdated and the unpatched softwares working in the systems

Importance and Conclusion :

Privilege escalation significantly increase impact of attack, Red teamers mainly focus on this phase to test the system security and configurations, many real world breaches occur due to simple misconfiguration rather than advance exploits. All the organisations should follow the principle of least privilege, patch their systems regularly and audit user permissions

“Privilege escalation is not about the tools, but the misconfigurations that get exploited.”

Web Application Attacks

Date : 02/12/2025

Introduction :

Web applications are widely used for banking, shopping, social media and business operations, these applications will handle the sensitive data of the users such as login credentials, personal data and financial informations. Web applications are easily accessible over the internet and they are the one of the most common targets for the attackers, in web application attacker attack refer to the exploiting weaknesses in web apps to gain unauthorised access and steal data and manipulate functions, in red teaming web application attacks play critical role in testing how the application is secure against the real world threats.

Explanation :

Most of the web applications accept the user inputs through the forms of URLs, Cookies and headers, these inputs is not properly validated or secured and attackers can easily manipulate it and start exploiting the web applications.

There are some certain causes why these attacks happen, the poor input validation, insecure authentication mechanisms, weak session management etc

In web application attackers dont need direct access to the systems, they can easily controllable remotely and make changes in that.

Types of the web application attacks :

1. **SQL Injection** : This occurs when user inputs the directly used in database queries and it allows the attackers to read, modify, or delete the databases data, it can lead to complete database compromise
Example SQL Injection payload : ' UNION SELECT username, password FROM users–
2. **Cross - Site Scripting** : This will happen when malicious scripts are injected into web pages and it will affect the users who visits the vulnerable page and can be used to steal the session cookies or perform actions on behalf of users
Example XSS payload : ">
3. **Cross - Site Request forgery** : This will trick the users into performing unwanted actions and try to exploit the trust between the user and web application and it will commonly affects the applications without proper request validations.
Example CSRF payload : "><svg/onload=alert(document.domain)>

Importance and Conclusion :

Web applications attacks are the most common among the causes of data breaches, the red teamers use these attacks to identify the real wold risks in applications many of the vulnerabilities exists due to insecure coding practices and poor configurations in the web applications, Organisations should implement some of the secure coding standards, validate and sanitise user inputs and implement strong authentication and access controls.

“Web applications Attacks often begin with when an user inputs meets the untrusted execution”

Active Directory Attacks

Date : 04/12/2025

Introduction :

Active directory is a important component used in the most of the enterprise windows environment, it manages users, computers, permissions, authentication, and access controls, most of the AD controls the entire network it becomes an highly valued target for the attackers. Active directory attacks refer to the techniques used to abuse misconfigurations, weak credentials and trust relationships with in AD, In red teaming AD attacks are very much critical because compromising AD often means full domain compromise.

Explanation :

Active directory works on trust, authentication and centralised management, if an attacker gains access to a single domain user, they can easily start exploiting with in the AD environment. Attackers usually look for the weak passwords, excessive user privileges etc.

AD attacks usually dont rely on the advanced exploits, most attacks succeed due to the misconfigurations and poor security system, in this the attacker goal will be escalate privileges and gain the domain admin access.

Types of Active Directory :

1. **Credential based attacks** : In this attack the attackers abuse the weak or reused passwords and steal the credentials and allow the lateral movement within the domain and often this will be the often starting point of the AD attacks.
2. **Privilege escalation in AD** : In this the attackers abuse the group memberships or delegated permissions and misconfiguration admin rights can lead to higher privileges like root access and in gain control over the critical AD objects and data.

Importance and Conclusion :

Active directory attacks often results in complete network compromise and red teamers mainly focus on the AD to test real world enterprise security, most successful AD attacks get exploited due to weak credentials, poor monitoring etc, and the organisations should focus on the enforce strong password policies, follow the least privilege principles and regularly audit the AD configurations.

“In Active Directory one weak account can open the door to the entire network”

Misconfigured Services as an attack vector

Date : 06/12/2025

Introduction :

Services are background programs that will be running continuously to perform the system or network tasks, these services often run with the elevated privileges and are very much critical for system functionality. A misconfigured service can be unintentionally expose sensitive systems resources and these will lead to the attack vector when an attackers abuse them to gain unauthorised access, in this the service misconfigurations are common and high impact entry points.

Explanation :

Some services are designed to automate the tasks and improve the system efficiency, when services are configured incorrectly they may run with the excessive privileges and expose unnecessary network ports, use the weak and hardcore credentials after getting these attackers dont need the advanced exploits they will use these as their keys and starts to exploit the systems, they analyse system behaviour to identify the services running as root or admin, they will check the insecure service permissions, they will try to access the services through the network.

Types of Misconfigured Services :

1. **Insecure Service permissions** : In this, the improper file or execution permissions on service binaries and the attackers may modify or replace service components easily.
2. **Exposed network services** : In this, the services accessible externally without proper restrictions and increases attack surface significantly.
3. **Weak or hardcoded credentials** : In this, the services which are using the embedded credentials and these credentials will be reused for lateral movement.

Importance and Conclusion :

Misconfiguration services are one of the most exploited weaknesses in the real world attacks and the red teamers target these issues to test the system like how its exactly working and all and most of the attacks succeed due to the configuration mistakes rather than software flaws, and the organisations should audit the running services and remove unnecessary services, enforce least privilege for service accounts.

“A single misconfiguration service can quietly hand over full control of the system”

Endpoint security bypass concepts

Date : 08/12/2025

Introduction :

In red teaming the understanding of the bypass concepts helps assess how resilient endpoint defenses are, the endpoint security includes antivirus, endpoint detection and response and host based protection systems, these solutions are designed to detect, block and respond to the malicious activities going in the devices and the systems. Attackers often attempt to bypass the endpoint security to remain undetected, this refers to the techniques used to avoid or weaken the security controls rather than directly breaking them.

Explanation :

End point security rely on the signatures, behavioural analysis, system monitoring etc, these are the things the attackers will study and get to know how the defense system works to prevent it, instead of directly attacking the security software they will avoid the suspicious actions which are blend into the normal system behaviour. In endpoint security the bypass techniques will be focused on the reducing detections, delaying the alerts, evading the monitoring mechanisms.

Many of the bypasses succeed due to outdated rules and misconfigurations or poor visibilities.

Types of Endpoint security bypass :

1. **Living off the land** : This will be using the legitimate system tools which are already present in the systems and try to bypass the endpoint security.
2. **Fileless activity** : In this the bypass methods avoids the writing malicious files to disk, instead it operated in the memory and reduces the traditional antivirus detection.
3. **Obfuscation and Evasion** : In this, the malicious intent will be hidden and make the system looks harmless and within inside it will bypass the static detection mechanisms.
4. **Trusted process abuse** : Running process and actions through the trusted applications and the security tools may allow them by fully default.

Importance and Conclusion :

The Endpoint security bypass increases the likelihood of long term compromise, the red teamers will use these concepts to evaluate the detection and response capabilities, many of the bypass techniques exploit gaps in the visibility rather than weakness in tools.

All the organisations must and should focus on keeping the endpoint tools updated, improve the behavioural monitoring, correlate alerts with the user activity and train the teams to detect the subtle anomalies, strong endpoint security always depends on both the tools and awareness.

“The most dangerous threats are the ones who looks like very much normal activity ”

Shadow IT Security Risks

Date : 10/12/2025

Introduction :

Shadow IT referred to the use of software, devices, cloud services or applications without approval from the IT department, employees often use these tools to improve the productivity and convenience, however the unmanaged and unauthorised tools introduce serious security risks, in this Shadow IT creates blind spots where the security teams have no visibility or control over the systems and the security infrastructure. It is the valuable attack surface because it often lacks proper security controls.

Explanation :

Organisations usually define approved tools and security policies, in which the shadow IT occurs when users bypass these policies, there are some common examples included for this Shadow IT security risks are personal cloud storage, unauthorised collaboration tools, unapproved SaaS applications.

Some tools which are often used to store sensitive data, use weak authentication and lack monitoring and logging, attackers exploit shadow IT because it is rarely patched, audited and monitored, it is the most important thing because its often lacks proper security controls.

Types of Shadow IT security Risks :

1. **Data leakage** : The sensitive data stored in unmanaged platforms and it will be the highly risk of the accidental exposure.
2. **Weak Authentication** : Personal accounts and other accounts without strong security controls that it will lead to the increased risk of credential compromise.
3. **Lack of Monitoring** : Security teams cannot detect suspicious activity and attack go unnoticed for long period.

Importance and Conclusion :

Shadow IT significantly increase the organisational risk, the red teamers use it to identify unknown assets and attack paths, many breaches will originate from unmanaged applications and the organisations should increase the visibility into user activity, educate employees about risks, provide secure, approved alternatives and enforce the clear IT policies, Managing Shadow IT is essential for reducing hidden threats.

“What IT doesn’t see can hurt the entire organisation”

Zero Trust Security Model

Date : 12/12/2025

Introduction :

In red team and blue team, zero trust plays an key role in reducing attack impact, traditional security models assumed everything inside the network could be trusted, modern organisations use the cloud services, remote work and third party access this make the traditional perimeter based security model ineffective and make easy for the zero trust. This is a security model in which that assumes no user or system is trusted by default and every access request must be verified regardlessly of location.

Explanation :

Zero trust is based on the principle of “Never trust, always verify”, in this the trust is not granted permanently and it is continuously evaluated, each and every user, device, and application must provide the legitimacy before accessing the resource. The access decisions will be depend on the multiple factors such as user identity, device health, location and behaviour, even the external users are treated like the external users. Zero trust limits the attacker movements by reducing the excessive permissions and preventing the unrestricted internal access. Instead of the one time authentication the zero trust rely on continuous validation.

Core principles of Zero Trust :

1. **Verify Explicitly** : In this every access request must be authenticated and authorised, verification uses multiple signals such as identity, device security status, risk level etc. Access is granted only when the through verification is done.
2. **Least privilege access** : In this the users are given only the minimum access of the required to perform their job and this reduces the impact of the compromised accounts, it prevents the attackers from accessing the unrelated systems or data and it also helps to contain breaches to a limited level.
3. **Assume breach** : Zero trust operates under the assumption that attackers may already be present and this will lead to the security control focus such as limiting movement, detecting the abnormal behaviour etc. It will help the organisations respond faster to incidents

Importance and Conclusion :

Zero trust significantly reduces attack success and impact of the breaches, the red teamers use it to test how well access controls and segmentation works and many attacks fails in zero trust due to restricted movements and the organisations should implement the strong identity management, monitor the user and device behaviour and regularly review the access permissions

“In Zero Trust, access is earned every time but not assumed”

Advanced persistence in windows systems

Date : 14/12/2025

Introduction :

In red teaming the persistence testing helps evaluate how well an organisation can detect and remove the hidden threats, in this the persistence refer to the techniques which attackers use to maintain the long term access to the compromised system. In windows environment, the persistence is especially critical because systems are frequently restarted and updated and without persistence attackers loose the access once the system reboots or credentials change. In advanced persistence techniques the systems are to survive the changes and avoid detection.

Explanation :

Persistence ensures the continued access even after the system reboots, user logouts and password changes etc, the windows system offer many legitimate features that can be abused for persistence and the attackers prefer persistence methods that can blend into normal systems behaviour, use trusted windows mechanisms, Advanced persistence focuses more on stealth and reliability rather than the speed, instead of noisy actions the attacker aims to the remain hidden for long periods. Many persistence techniques succeed due to weak monitoring, poor system handling and overly trusted system components. Persistence is often combined with the privilege escalation to increase the effectiveness of the attacks.

Types of Advanced persistence techniques :

1. **Startup and boot level persistence** : In this the persistence mechanisms triggered during the system startup and allow attackers to regain the access after every reboot or restart, its often difficult to notice because startup processes are expected.
2. **Service and Scheduled Execution** : It uses the automated execution features built into windows and the actions occur at specific times or system events and it appear as legitimate because automation is common in enterprise environments
3. **User level persistence** : Persistence tied to the specific user accounts, it will get activated when the users log in and immediately affect the system stability, it is useful for maintaining low level profile, long term access.

Importance and Conclusion :

Advanced persistence allows the attackers to remain undetected for extended periods, red teamers use persistence testing to evaluate the detection and response maturity, many real world breaches last months due to unnoticed persistence mechanisms. Organisations should monitor the startup behaviour, Audit scheduled activities and services, enforce the proper logging and alerting methods.

“The real danger is not getting in, the real danger is staying hidden in”